

EXPOSICIÓN DE TICS

Malware y Ciberataques

Cuatro casos que cambiaron las reglas del juego

ORDEN DE LOS TEMAS:

- 01 · Virus Michelangelo (1992) --- Jhon Redrovan
- 02 · Hackeo a NVIDIA (2022) --- David Paucar
- 03 · Hackeo a Riot Games (2023) --- Kevin Quinga
- 04 · Pegasus / NSO Group (2016-hoy) --- Briam Leyva

El virus Michelangelo

APERTURA

Buenas tardes a todos. Vamos a hablarles de cuatro casos reales que marcaron la historia de los ciberataques, desde 1992 hasta la actualidad. Yo abro esta exposición con el más antiguo de los cuatro, pero no por eso el menos importante: el virus Michelangelo, uno de los primeros casos de pánico masivo provocado por un malware.

DESARROLLO

Corría el año 1991 cuando el dueño de una tienda de computadoras en Australia notó símbolos extraños en su pantalla. Al investigar, se descubrió un virus alojado en el sector de arranque del disco duro: un tipo de virus que se activa antes incluso de que cargue el sistema operativo. Este virus tenía una particularidad que lo hizo famoso: permanecía completamente dormido durante todo el año, y solo se activaba cada 6 de marzo, fecha del cumpleaños del pintor renacentista Miguel Ángel. De ahí su nombre.

El virus se propagaba a través de disquetes infectados, el medio de almacenamiento más común de la época. Bastaba con insertar un disquete contaminado en una computadora para que el virus se instalara en el sector de arranque del disco duro, y desde ahí, cualquier otro disquete que se insertara en esa misma máquina quedaba infectado también. Así, sin internet, sin redes, el virus viajaba físicamente de computadora en computadora.

Lo curioso es que varias empresas de tecnología, entre ellas Intel, distribuyeron por accidente discos y hasta computadoras nuevas que ya venían infectadas de fábrica. Esto aceleró muchísimo la propagación del virus antes de que nadie supiera que existía.

Cuando se descubrió qué pasaría el 6 de marzo de 1992 que el virus sobrescribiría los primeros sectores del disco duro, borrando datos de forma prácticamente irreversible, estalló el pánico. John McAfee, fundador de la empresa de antivirus que lleva su nombre, llegó a estimar públicamente que hasta cinco millones de

computadoras en el mundo podrían perder toda su información. Gobiernos, medios de comunicación y empresas de todo el planeta cubrieron la noticia como una amenaza inminente y catastrófica.

Pero cuando llegó el día, la realidad fue muy distinta a la predicción de McAfee, se reportaron entre diez mil y veinte mil casos de pérdida de datos, una cifra muy por debajo de los millones anunciados. Michelangelo terminó siendo, más que una catástrofe tecnológica, un estudio de caso sobre el pánico colectivo.

CIERRE DE REDROVAN

Michelangelo nos enseñó algo que se repetiría una y otra vez en la historia de la ciberseguridad: el miedo a un ciberataque puede volverse tan poderoso como el ataque mismo. Este caso también impulsó el nacimiento de la industria antivirus tal como la conocemos hoy. Pero treinta años después, los ataques dejaron de necesitar un disquete físico, pasaron a viajar por la nube, directo al corazón de las empresas de tecnología más grandes del mundo. De eso les va a hablar mi compañero o compañera a continuación, con el caso de NVIDIA.

El hackeo a NVIDIA

APERTURA

Gracias. Treinta años después de Michelangelo, el malware ya no viaja en disquetes, viaja por redes corporativas completas. Les voy a contar el caso de NVIDIA, una de las empresas de tecnología más valiosas del mundo, y cómo un grupo de extorsión no solo le robó información le robó algo mucho más peligroso, la confianza digital de su propio software.

DESARROLLO

En febrero de 2022, un grupo de ciberdelincuentes conocido como Lapsus\$ logró infiltrarse en los sistemas internos de NVIDIA. El propio grupo afirmó haber permanecido dentro de la red de la empresa durante aproximadamente una semana antes de ser detectado, tiempo que aprovecharon para robar cerca de un terabyte de información interna, incluyendo credenciales de miles de empleados.

A diferencia de un ataque puramente destructivo, este fue un ataque de extorsión. Lapsus\$ exigió a NVIDIA algo muy específico y poco común, eliminar una función llamada LHR, que limitaba el rendimiento de sus tarjetas gráficas RTX 30?? para minería de criptomonedas. A cambio de esa concesión, prometían no filtrar los datos robados.

NVIDIA se negó a negociar. Y como suele suceder en estos casos, el grupo cumplió su amenaza, publicó los datos robados en un sitio de filtraciones, disponibles para cualquiera que quisiera descargarlos.

Aquí es donde el caso se vuelve verdaderamente peligroso. Entre los archivos filtrados había dos certificados de firma de código, herramientas que NVIDIA usaba para autenticar sus controladores y programas, garantizando a los usuarios que ese software era legítimo y no había sido alterado. Aunque ambos certificados estaban técnicamente vencidos, el sistema operativo Windows seguía aceptándolos como válidos para firmar controladores.

En cuestión de días, otros grupos de ciberdelincuentes, completamente ajenos a Lapsus\$, comenzaron a usar esos certificados robados para firmar su propio

malware, troyanos de acceso remoto, herramientas de post-explotación como Mimikatz, y programas maliciosos diseñados para infiltrarse en otros sistemas. Al estar firmados con un certificado de NVIDIA, Windows los reconocía como software confiable, permitiéndoles pasar desapercibidos frente a muchas herramientas de seguridad.

CIERRE DE PAUCAR

Este caso nos deja una lección clave. Robar datos ya no es el único objetivo de un ciberataque moderno. Robar la confianza digital misma, certificados, credenciales, infraestructura puede armar a otros criminales durante años, mucho después de que el ataque original haya terminado. Pero, ¿cómo logró Lapsus\$ entrar en primer lugar a una empresa con tanta seguridad? La respuesta, en la mayoría de estos casos, casi nunca es una falla puramente técnica, es una persona. Y de eso trata exactamente el siguiente caso, el de Riot Games.

El hackeo a Riot Games

APERTURA

Gracias. En el caso anterior vimos cómo un grupo de extorsión robó certificados digitales de NVIDIA. Ahora les voy a mostrar cómo, apenas un año después, otro ataque de altísimo impacto no necesitó explotar ninguna falla técnica compleja: le bastó con engañar a una sola persona. Este es el caso de Riot Games, la empresa creadora de League of Legends y Valorant.

DESARROLLO

En enero de 2023, Riot Games sufrió un ataque que comenzó de la forma más simple posible, con un mensaje de texto. Los atacantes obtuvieron el número telefónico de un empleado de la compañía, expuesto previamente en alguna filtración de datos anterior, y lo usaron como punto de entrada.

A través de ese contacto, utilizando técnicas de ingeniería social es decir, manipulación psicológica en lugar de herramientas de hackeo tradicionales, lograron engañar al empleado para obtener acceso al entorno de desarrollo interno de la compañía. No hubo que vulnerar ningún sistema complejo, bastó con ganarse la confianza, o generar la urgencia suficiente, para que una persona bajara la guardia.

Con ese acceso, los atacantes lograron robar el código fuente completo de League of Legends, de Teamfight Tactics, y de una plataforma anti-trampas de la compañía, incluyendo funciones y contenido que ni siquiera habían sido publicados todavía.

Poco después, Riot Games recibió un correo de extorsión. Los atacantes exigían diez millones de dólares a cambio de no filtrar ni vender el código robado públicamente. La empresa se negó a pagar, y lo anunció de forma abierta y transparente en sus redes sociales, explicando la situación directamente a su comunidad de jugadores en lugar de intentar resolverlo en silencio.

Riot confirmó que ningún dato personal de jugadores fue comprometido en el ataque, lo cual fue una buena noticia. Sin embargo, el robo del código fuente sí tuvo

consecuencias reales. Retrasó el lanzamiento de parches y actualizaciones, y abrió la puerta a que aparecieran nuevas formas de hacer trampa en sus juegos, ya que los tramposos ahora tenían acceso directo a cómo funcionaba internamente el software anti-trampas.

CIERRE DE MI PARTE

Este caso demuestra algo fundamental en ciberseguridad: ni las certificaciones ni los firewalls más avanzados del mundo sirven de nada si un solo empleado puede ser engañado con un simple mensaje de texto. La tecnología puede ser perfecta, pero las personas siguen siendo el punto más vulnerable de cualquier sistema. Y ese mismo principio apuntar directamente a las personas, en lugar de a las máquinas es, en realidad, la base del caso más inquietante de los cuatro que vamos a revisar hoy: el caso de Pegasus, del que les va a hablar mi compañero para cerrar esta exposición.

Pegasus, el software de NSO Group

APERTURA

Gracias. Hemos visto un virus que sembró pánico mundial, una empresa que perdió el control de su propia confianza digital, y una compañía de videojuegos vulnerada por un simple mensaje de texto. Para cerrar esta exposición, les voy a hablar del expediente más inquietante de los cuatro. Pegasus, un software capaz de convertir cualquier teléfono en una herramienta de vigilancia total, sin que su dueño tenga que hacer absolutamente nada.

DESARROLLO

Pegasus es un spyware, es decir, un software espía, desarrollado por la empresa israelí NSO Group. Oficialmente, la compañía lo comercializa como una herramienta para que los gobiernos combatan el terrorismo y el crimen organizado. Sus clientes son, en teoría, agencias gubernamentales autorizadas.

Lo que hace a Pegasus fundamentalmente distinto de todos los casos anteriores es su método de infección, es un ataque conocido como "zero-click", es decir, de cero clics. A diferencia de un virus tradicional o de un ataque de ingeniería social como el de Riot Games, Pegasus no necesita que la víctima haga clic en ningún enlace, ni descargue ningún archivo, ni cometa ningún error. Puede infectar un teléfono explotando fallas invisibles en aplicaciones como iMessage, sin dejar rastro alguno de interacción por parte del usuario.

Una vez instalado, Pegasus le da al atacante un control prácticamente total sobre el dispositivo: puede leer todos los mensajes, escuchar llamadas, activar de forma remota la cámara y el micrófono sin que se encienda ningún indicador visible, y rastrear la ubicación exacta de la persona en todo momento.

En julio de 2021 se publicó el Proyecto Pegasus, una investigación coordinada por la organización Forbidden Stories y Amnistía Internacional, en la que participaron más de ochenta periodistas de diecisiete medios de comunicación distintos. La investigación reveló una lista filtrada de más de cincuenta mil números telefónicos que habían sido seleccionados como posibles objetivos de vigilancia por clientes de

NSO Group. Entre los identificados había periodistas, activistas de derechos humanos, abogados, y hasta jefes de estado y ministros de varios países.

Las consecuencias no se hicieron esperar. Estados Unidos incluyó a NSO Group en su lista negra comercial en 2021, restringiendo su acceso a tecnología estadounidense. Apple presentó una demanda legal contra la empresa para intentar frenar el uso indebido de este tipo de software espía patrocinado por estados. El Parlamento Europeo, por su parte, abrió una comisión de investigación específica sobre el uso de Pegasus en territorio europeo. Aun así, y esto es lo más preocupante, se han seguido documentando nuevos casos de infección con Pegasus en los años posteriores a estas medidas.

CIERRE Y CONCLUSIÓN

Con esto llegamos al final de nuestro recorrido por estos cuatro casos. De Michelangelo a Pegasus hay treinta años de diferencia, pero una misma lógica se repite, cada avance en la tecnología abre una nueva puerta, y siempre hay alguien dispuesto a forzarla. Vimos cómo el malware evolucionó desde un virus que buscaba destruir archivos a la vista de todos, hasta un software capaz de espiar en absoluto silencio, sin ser detectado jamás. Aquí la pregunta no es si habrá un próximo ciberataque, porque sabemos que lo habrá. La verdadera pregunta es qué tan preparados estamos, como usuarios, como empresas y como sociedad, para el que viene después. Muchas gracias por su atención.